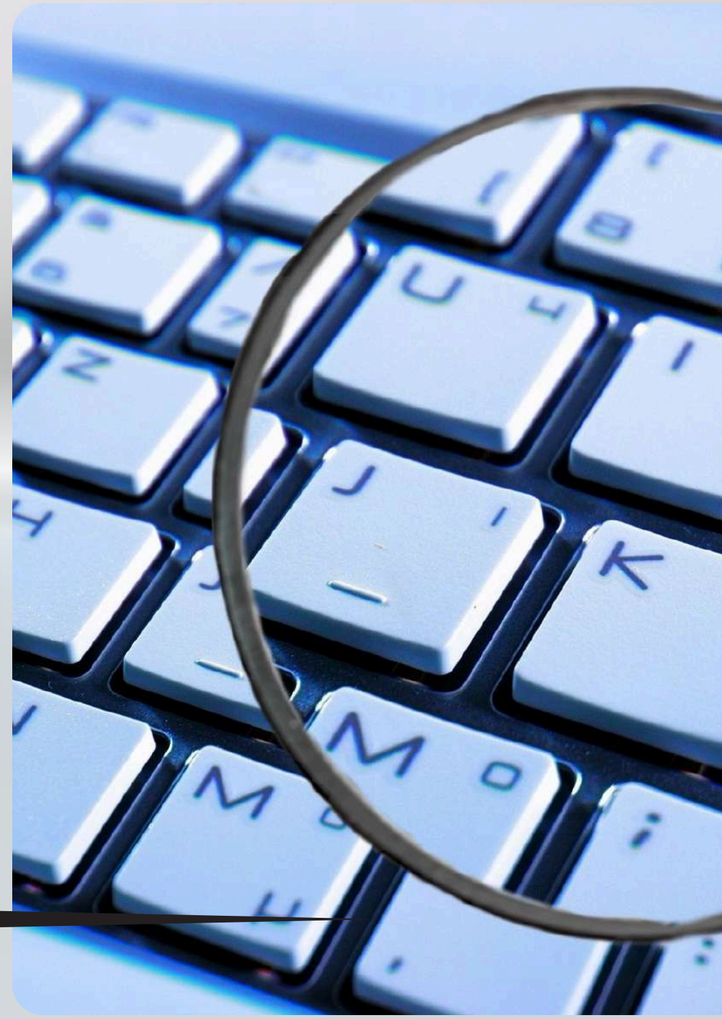
VULNABILITY ASSESSMENT REPORT

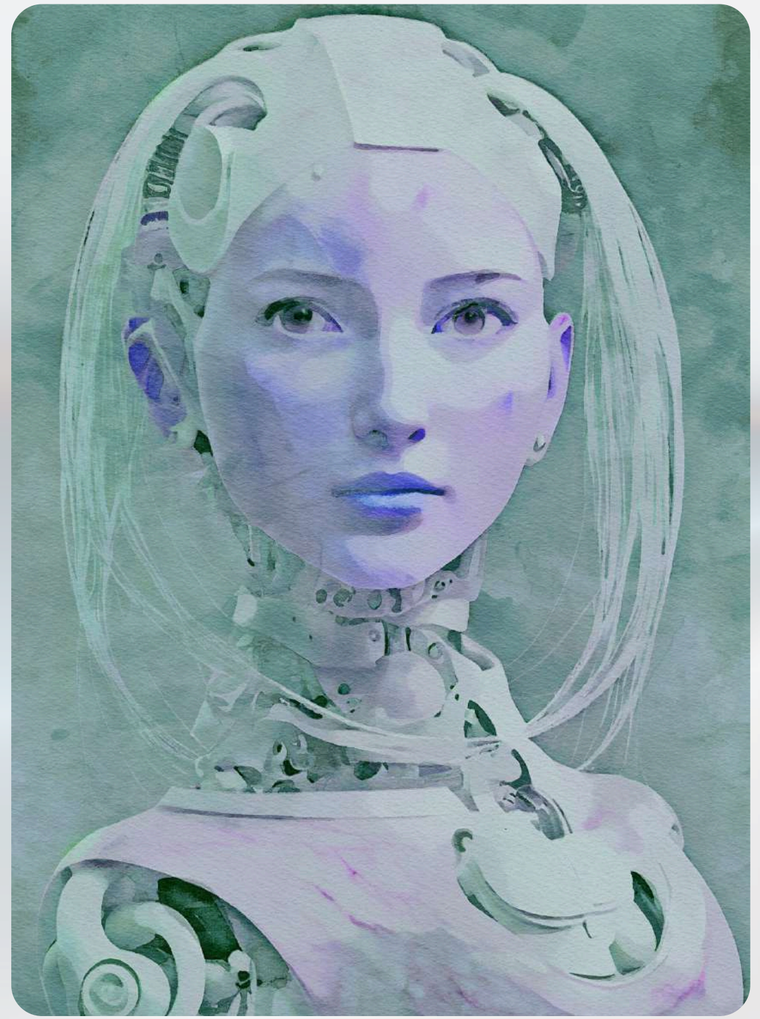
Zero Bank Web Application
http://zero.webappsecurity.com
April 27, 2026

Executive Summary

A vulnerability assessment was conducted on Zero Bank's web application using Nmap, OWASP ZAP, and Browser DevTools. A total of 10 security issues were identified including 3 HIGH risk vulnerabilities. Immediate remediation is required to protect customer data and prevent potential attacks.

Overall Risk Rating: HIGH





Assessment Methodology

- Nmap 7.99 — Scanned open ports and detected server infrastructure
- OWASP ZAP (Passive) — Spidered the application, found 10 vulnerabilities
- Browser DevTools — Inspected HTTP headers, cookies, and console errors

Target: http://zero.webappsecurity.com
IP Address: 44.228.249.3 (AWS EC2 - us-west-2)

Risk Summary

- HIGH RISK — 3 findings
- MEDIUM RISK — 4 findings
- LOW RISK — 1 finding
- INFORMATIONAL — 2 findings

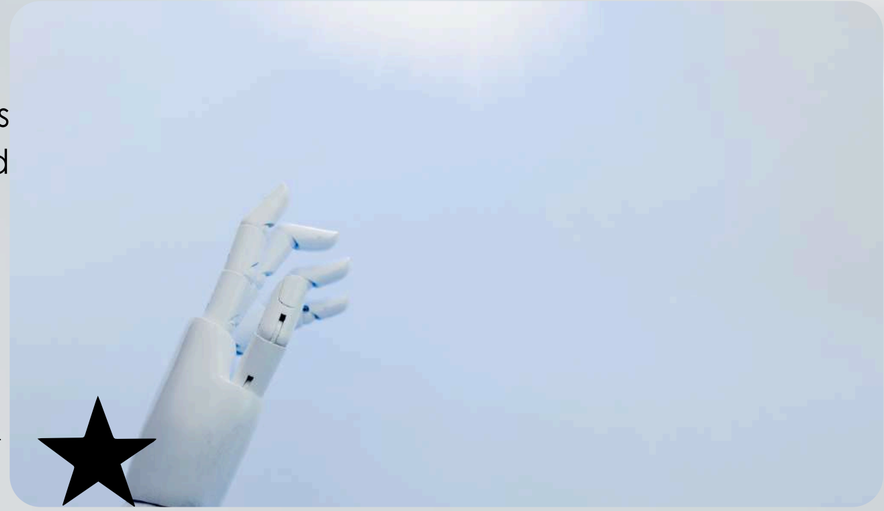
Total: 10 Vulnerabilities Identified

Finding #1 — CSP Header Not Set [HIGH]

Tool: OWASP ZAP
Affected: All pages on zero.webappsecurity.com

What it means: The website has no Content Security Policy. This allows attackers to inject malicious scripts that steal customer passwords and banking credentials.

Fix: Add header → Content-Security-Policy: default-src 'self'
Priority: Immediate



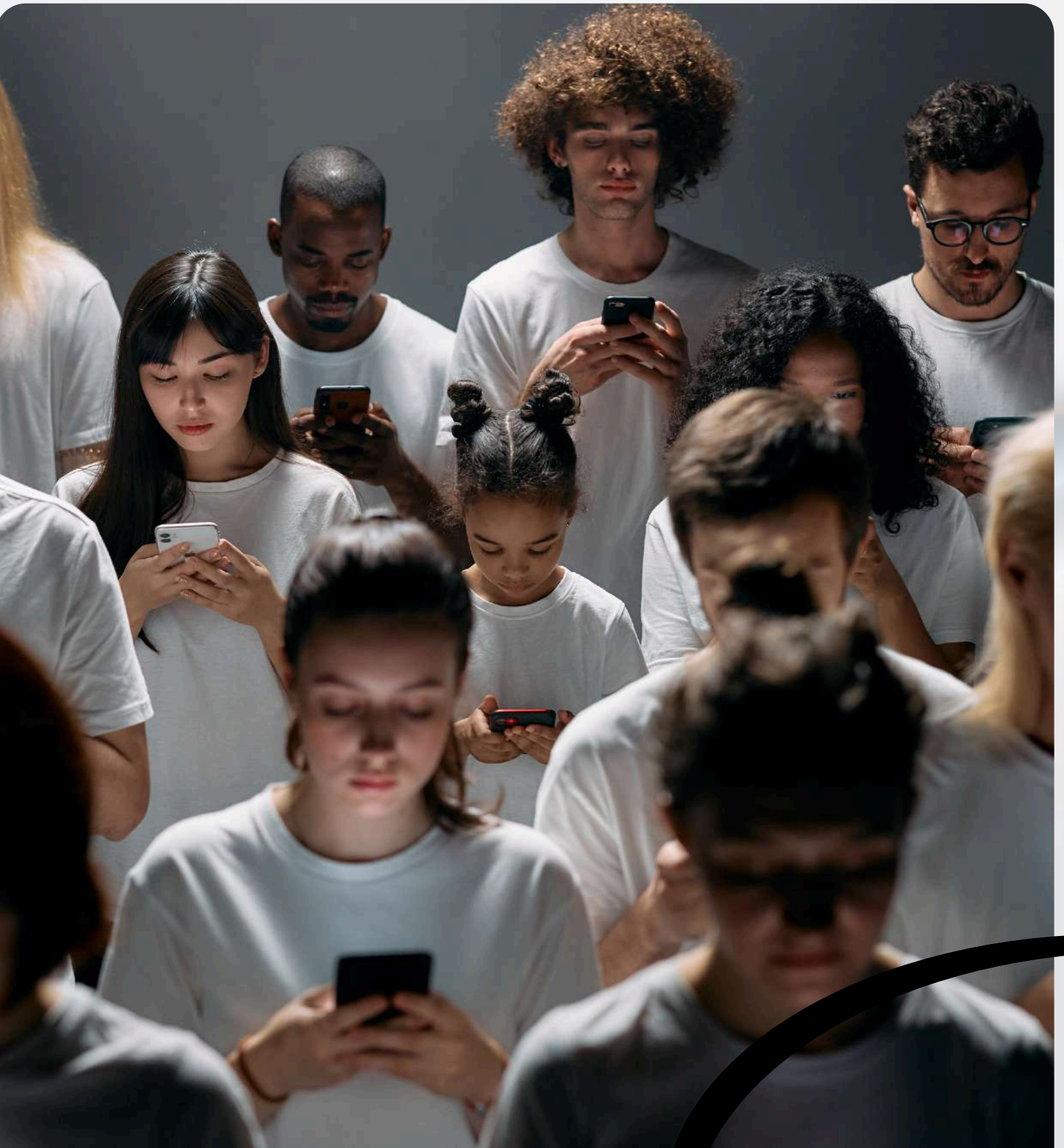
★★★★★

Finding #2 — Cross-Domain Misconfiguration [HIGH]

Tool: OWASP ZAP + Browser DevTools
Affected: http://zero.webappsecurity.com

What it means: The server allows ANY website to access its data (Access-Control-Allow-Origin: *). A malicious site can silently steal customer banking information.

Fix: Replace * with specific trusted domains only
Priority: Immediate



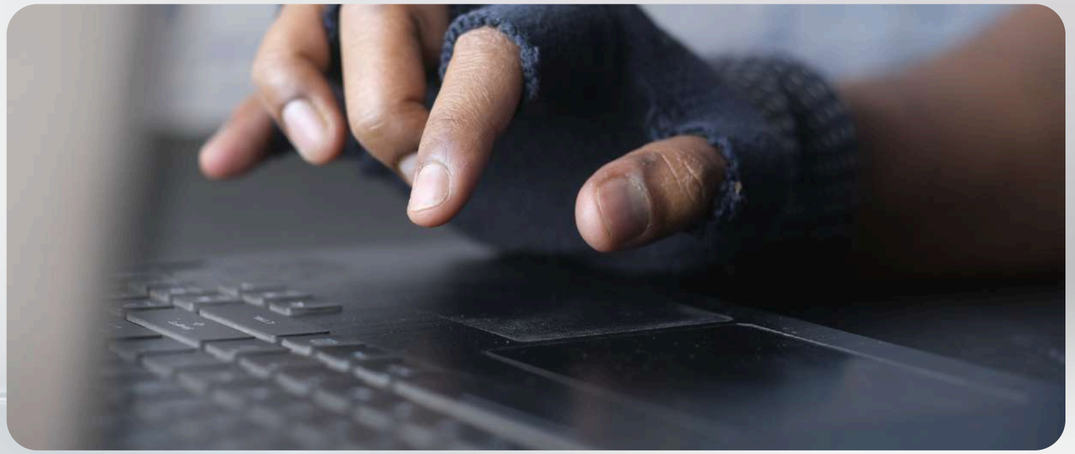
Finding #3 — Vulnerable JS Library [HIGH]

Tool: OWASP ZAP
Affected: /resources/js/jquery-1.8.2.min.js

What it means: The site uses jQuery version 1.8.2 from 2012 — over 13 years old with multiple known exploits that attackers can use to steal data.

Fix: Upgrade jQuery to version 3.7 or later
Priority: Immediate

Finding #4 — Missing Anti-Clickjacking Header [MEDIUM]



Tool: OWASP ZAP
Affected: 4 pages including homepage and search

What it means: The site can be embedded inside another website invisibly. Attackers can trick users into clicking hidden buttons, authorizing fraudulent transactions unknowingly.

Fix: Add header → X-Frame-Options: DENY
Priority: Within 1 week

Finding #5 — Server Version Info Leaked [MEDIUM]

Tool: OWASP ZAP + Browser DevTools
Server Header: Apache-Coyote/1.1

What it means: The server announces its exact software version to anyone who asks. Attackers can look up known exploits for this specific version.

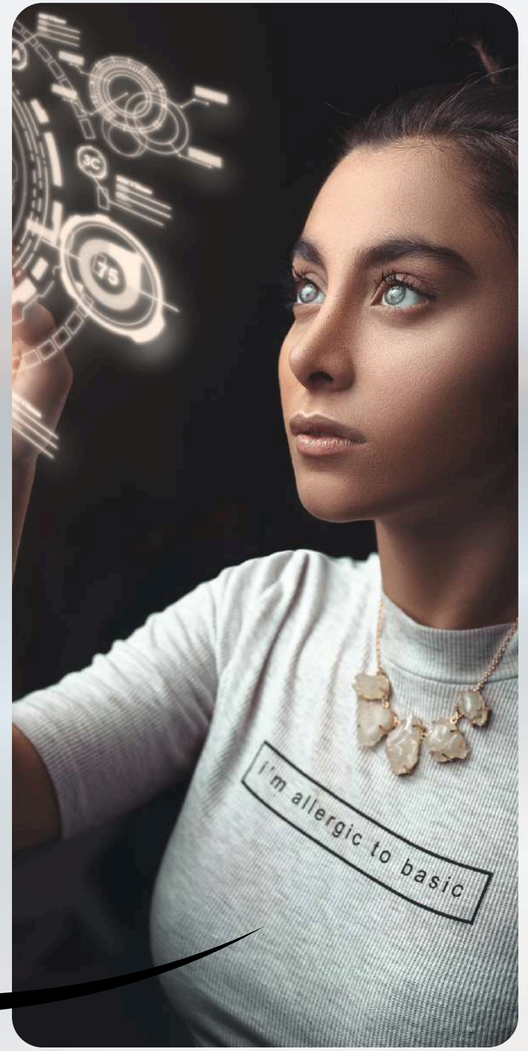
Fix: Suppress server version in HTTP response headers
Priority: Within 1 week

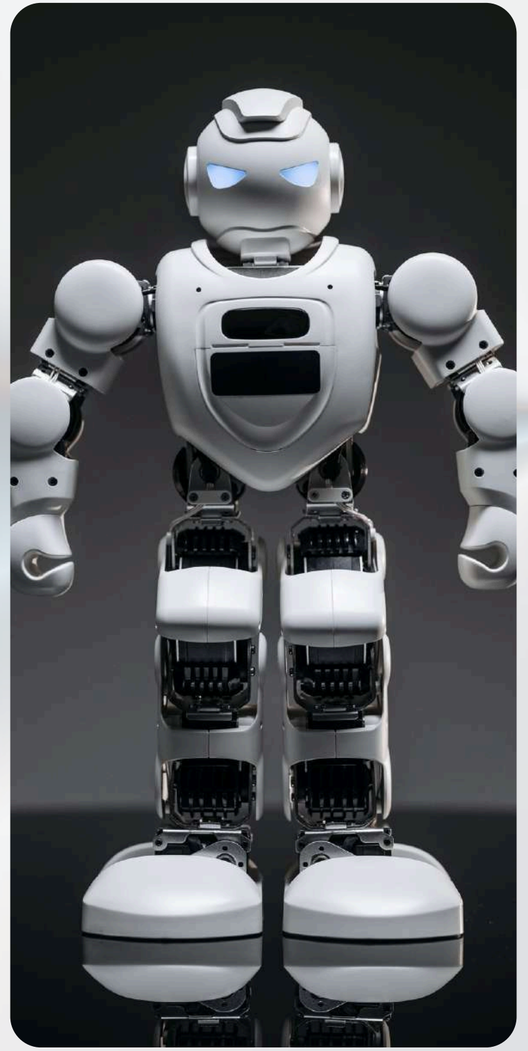
Finding #6 — In Page Banner Information Leak [MEDIUM]

Tool: OWASP ZAP
Affected: /resources/css/, /img/, /js/, /robots.txt, /sitemap.xml

What it means: The website exposes its full internal structure through publicly accessible files. Robots.txt and sitemap.xml reveal hidden pages including possible admin panels that attackers can target directly.

Fix: Restrict directory browsing. Remove sensitive paths from robots.txt and sitemap.xml. Ensure admin pages require authentication.
Priority: Within 1 week





Finding #7 — X-Content-Type-Options Header Missing [MEDIUM]

Tool: OWASP ZAP
Affected: Homepage, main.css, bootstrap.min.js, placeholders.min.js

What it means: Without this header, browsers may guess the file type of responses and accidentally execute malicious files as scripts. An attacker who uploads a file could use this to run harmful code in a victim's browser.

Fix: Add header → X-Content-Type-Options: nosniff to all responses
Priority: Within 1 week

Finding #8 — Information Disclosure via Code Comments [LOW]

Tool: OWASP ZAP
Affected: /resources/js/jquery-1.8.2.min.js

What it means: Developer notes and comments left inside JavaScript files reveal internal implementation details. These hints help attackers understand the application structure and craft more targeted attacks.

Fix: Remove all developer comments before deploying to production. Use an automated minifier or bundler that strips comments automatically during the build process.
Priority: Within 2-4 weeks

Remediation Priority Plan

🔴 P1 — IMMEDIATE (24-48 hours)
- Upgrade jQuery 1.8.2 to version 3.7+
- Fix CORS policy — remove wildcard (*)

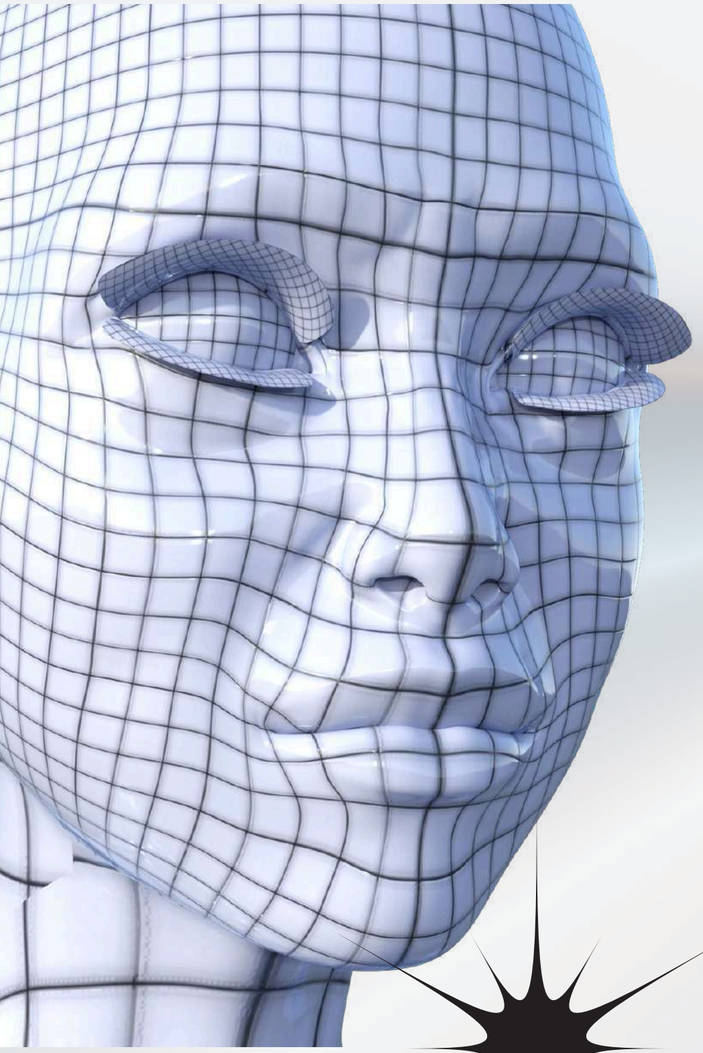
🟡 P2 — SHORT TERM (Within 1 week)
- Add Content-Security-Policy header
- Add X-Frame-Options: DENY
- Add X-Content-Type-Options: nosniff
- Suppress server version in HTTP headers
- Restrict directory browsing and fix robots.txt

🟢 P3 — MEDIUM TERM (2-4 weeks)
- Remove developer comments from JS files

🔵 P4 — ONGOING
- Regular vulnerability scans every 3 months
- Keep all libraries and frameworks up to date

CONCLUSION

The assessment identified 10 vulnerabilities on Zero Bank's web application. Three critical issues require immediate action — an outdated JavaScript library, permissive CORS policy, and missing Content Security Policy. Fixing these issues will significantly reduce the risk of data theft and customer harm. A follow-up assessment is recommended after remediation.



Thank You

Assessment Complete

Conducted by: EVANS NJENGA WAWERU

Date: April 27, 2026

Tools: Nmap | OWASP ZAP | Browser DevTools